



Figure 1: Reported Attack Page

a website can be a criminal offence.) In addition, a local copy meant that there was no Intrusion Detection System to counter, and the scan would finish much faster at LAN speeds than over an Internet connection.

The Nikto scan revealed some interesting information—the site had been attacked using two exploits: *microsoftofficewebserver* and *x-pingback*. Here's the output of the scan, with client-specific references obfuscated:

```
nikto -host XX.XXX.XXX.XX -vhost www.XXXXXXX.XXX -p 80 443
- Nikto v2.1.1
-----
+ Target IP: X.XXX.XXX.XX
+ Target Hostname: IP.TargetHostname.com
+ Target Port: 80
+ Virtual Host: www.XXXXXXX.org
+ Start Time: 2010-XX-XX 13:02:35
-----
+ Server: Microsoft-IIS/6.0
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST
+ Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST
+ Microsoft-IIS/6.0 appears to be outdated (4.0 for NT 4, 5.0 for Win2k,
current is at least 7.0)
+ Retrieved X-Powered-By header: ASP.NET
+ GET /: Retrieved X-Powered-By header: PHP/4.4.7
+ GET /: Uncommon header 'x-pingback' found, with contents: http://www.
XXXXXX.XXX /xmlrpc.php
+ Retrieved microsoftofficewebserver header: 5.0_Pub
+ Uncommon header 'microsoftofficewebserver' found, with contents: 5.0_Pub
+ OSVDB-12184: /index.php?PHP8885F2A8-3C92-11d3-A3A9-4C7B08C10000: PHP
reveals potentially sensitive information via certain HTTP requests which
contain specific QUERY strings.
+ OSVDB-3092: /test/: This might be interesting...
+ OSVDB-3092: /LICENSE.txt: License file found may identify site software.
+ OSVDB-3092: /xmlrpc.php: xmlrpc.php was found.
+ /wp-content/plugins/akismet/readme.txt: The WordPress Akismet plugin
'Tested up to' version usually matches the WordPress version
+ /readme.html: This WordPress file reveals the installed version.
+ OSVDB-3092: /License.txt: License file found may identify site software.
+ OSVDB-3092: /LICENSE.TXT: License file found may identify site software.
+ 3823 items checked: 14 item(s) reported on remote host
+ End Time: 2010-03-11 13:47:19 (2684 seconds)
```

Important terms

Asset: A resource of value, such as the data in a database or on the file system, a system resource, etc.
Threat: A potential occurrence (malicious or otherwise) that may harm an asset.
Vulnerability: A weakness or entry point that makes a threat possible.
Attack: Hostile action taken to harm an asset.
Exploit: A security hole which can potentially allow an attack.
Countermeasure: A safeguard that addresses a threat and mitigates risk.

+ 1 host(s) tested

A Google search revealed that the exploits were related to the popular WordPress publishing platform used for the website, and also revealed possible solutions to the problem. The website was vulnerable to attack because the website developers had not taken the trouble to install updated versions that addressed known vulnerabilities.

After updating the local copy of the site according to the recommendations, Kedar ran another Nikto scan. A few more security vulnerabilities were reported, including a few unnecessary folders on the website. The errors were corrected, and when a final Nikto scan verified that the site didn't have any known vulnerabilities, it was uploaded to the Web server, overwriting the compromised site. The site has been up and running perfectly till date.

The anatomy of an attack

Now that the website was back up, Kedar explained the details of the incident to Shree from scratch, beginning with defining what Web pages, websites and Web applications were, and the importance of securing them. We'll skip much of those elementary concepts, however, and move on to the analysis of how website attacks happen.

One of the biggest considerations for websites and Web applications is that they are required to be up and running 24x7. They are potentially accessible to anybody around the world, round the clock. Sensitive information that can be misused for monetary gain, or used to hold the site owners to ransom, coupled with the 24x7 availability of the site, attracts crackers to attack the site to access confidential data.

An attacker's basic approach to breaking into a Web server is as follows:

1. **Survey and assess the potential target:** The attackers find out what types of services are being used on the target website, what operating system and Web server software versions it runs, the additional software used, etc, and attempt to find possible vulnerabilities and entry points in supported services and protocols. This information is then used to plan the initial attack.
2. **Exploit and penetrate the target:** The attackers then use attacks corresponding to the discovered vulnerability